

Blog

[Home](#) > [Blog](#) > [Technical Insight](#) > Top 10 Web Hacking Techniques of 2015



[TECHNICAL INSIGHT](#) - [TOOLS AND APPLICATIONS](#) - [VULNERABILITIES](#) - [WEB APPLICATION SECURITY](#)

Top 10 Web Hacking Techniques of 2015

[Kuskos](#) | January 12, 2016

UPDATE – 4/20/2016 We have our Top 10 list folks! After a lot of coordination, research, voting by the community and judging by our esteemed panelists, we are pleased to announce our Top 10 List of Web Hacking Techniques for 2015:

1. [FREAK \(Factoring Attack on RSA-Export Keys\)](#)
2. [LogJam](#)
3. [Web Timing Attacks Made Practical](#)
4. [Evading All* WAF XSS Filters](#)
5. [Abusing CDN's with SSRF Flash and DNS](#)
6. [IllusoryTLS](#)
7. [Exploiting XXE in File Parsing Functionality](#)
8. [Abusing XLSX for Practical Attacks](#)
9. [Magic Hashes](#)
10. [Hunting Asynchronous Vulnerabilities](#)

Congratulations to the team that discovered FREAK!

The FREAK attack was [discovered](#) by [Karthikeyan Bhargavan](#) at INRIA in Paris and the [miTLS team](#). Further disclosure was coordinated by [Matthew Green](#). This report is maintained by computer scientists at the University of Michigan, including [Zakir Durumeric](#), [David Adrian](#), Ariana Mirian, [Michael Bailey](#), and [J. Alex Halderman](#). The team can be contacted at freakattack@umich.edu.

Congratulations to all those that made the list! Your research contributions are admired and should be respected. And a special thanks to everyone that voted or shared feedback. Also, for anyone that would be interested in learning more about this list, Johnathan Kuskos will be presenting the list at [AppSec Europe on June 1st](#). Come check it out!

You can also attend the [Top Ten Web Hacks of 2015 webinar](#).

Agree with the list? Disagree? Share your comments below.

TRENDING NOW

INDUSTRY SOLUTIONS

[Podcast](#)

THOUGHT LEADERSHIP

[Industry Observations](#)

SECURITY RESEARCH

[Aviator](#)

[Technical Insight](#)

[Tools And Applications](#)

[True Stories Of The](#)

[TRC](#)

[Unsung Heroes](#)

[Vulnerabilities](#)

[WhiteHat HackerKast](#)

WHITEHAT SENTINEL

[Events](#)

[Web Application Security](#)

END UPDATE

With 2015 coming to a close, the time has come for us to pay homage to top tier security researchers from the past year and properly acknowledge all of the hard work that has been given back to the Infosec community. We do this through a nifty yearly process known as The Top 10 Web Hacking Techniques list. Every year the security community produces a stunning number of new Web hacking techniques that are published in various white papers, blog posts, magazine articles, mailing list emails, conference presentations, etc. Within the thousands of pages are the latest ways to attack websites, Web browsers, Web proxies, and their mobile platform equivalents. Beyond individual vulnerabilities with CVE numbers or system compromises, we are solely focused on new and creative methods of Web-based attack. Now in its tenth year, the Top 10 Web Hacking Techniques list encourages information sharing, provides a centralized knowledge base, and recognizes researchers who contribute excellent research. Previous Top 10's and the number of new attack techniques discovered in each year are as follows:

[2006](#) (65), [2007](#) (83), [2008](#) (70), [2009](#) (82), [2010](#) (69), [2011](#) (51), [2012](#) (56), [2013](#) (31), and [2014](#) (46).

The vulnerabilities and hacks that make this list are chosen by the collective insight of the infosec community. **We rely 100% on nominations, either your own or another researcher, for an entry to make this list!**

Phase 1: Open community submissions [Jan 11-Feb 1]

Comment this post or email us [top10Webhacks\[at\]whitehatsec\[dot\]com](mailto:top10Webhacks[at]whitehatsec[dot]com) with your submissions from now until Feb 1st. The submissions will be reviewed and verified.

Phase 2: Open community voting for the final 15 [Feb 1-Feb 8]

Each verified attack technique will be added to a survey which will be linked below on Feb 1st. The survey will remain open until Feb 8th. Each attack technique (listed alphabetically) receives points depending on how high the entry is ranked in each ballot. For example, an entry in position #1 will be given 15 points, position #2 will get 14 points, position #3 gets 13 points, and so on down to 1 point. At the end, all points from all ballots will be tabulated to ascertain the top 15 overall.

Phase 3: Panel of Security Experts Voting [Feb 8-Feb 15]

From the result of the open community voting, the final 15 Web Hacking Techniques will be ranked based on votes by a panel of security experts. (Panel to be announced soon!) Using the exact same voting process as Phase 2, the judges will rank the final 15 based on novelty, impact, and overall pervasiveness. Once tabulation is completed, we'll have the Top 10 Web Hacking Techniques of 2015!

Current List of 2015 Submissions (in no particular order)

- [Logjam](#)
- [Abusing XSLT for Practical Attacks](#)

- [Java Deserialization w/ Apache Commons Collections in WebLogic, WebSphere, JBoss, Jenkins, and OpenNMS](#)
- [Breaking HTTPS with BGP Hijacking](#)
- [Pawn Storm \(CVE-2015-7645\)](#)
- [Superfish SSL MitM](#)
- [Bypass Surgery](#)
- [Abusing CDNs with SSRF Flash and DNS](#)
- [Google Drive SSO Phishing](#)
- [Dom Flow](#)
- [Untangling The DOM For More Easy-Juicy Bugs](#)
- [Password mining from AWS/Parse Tokens](#)
- [St. Louis Federal Reserve DNS Redirect](#)
- [Exploiting XXE in File Upload Functionality](#)
- [Expansions on FREAK attack](#)
- [eDellRoot](#)
- [WordPress Core RCE](#)
- [FileCry](#)
- [The New Age of XXE](#)
- [Server-Side Template Injection: RCE for the Modern Web App](#)
- [IE11 RCE](#)
- [Understanding and Managing Entropy Usage](#)
- [Attack Surface for Project Spartan's EdgeHTML Rendering Engine](#)
- [Web Timing Attacks Made Practical](#)
- [Winning the Online Banking War](#)
- [CNNINC SSL MitM](#)
- [New Methods in Automated XSS Detection: Dynamic XSS Testing Without Using Static Payloads](#)
- [Practical Timing Attacks using Mathematical Amplification of Time Difference in == Operator](#)
- [The old is new, again. CVE20112461 is back!](#)
- [illusoryTLS](#)
- [Hunting ASynchronous Vulnerabilities](#)

- [New Evasions for Web Application Firewalls](#)
- [Magic Hashes](#)
- [Formaction Scriptless attack updates](#)
- [The Unexpected Dangers of Dynamic JavaScript](#)
- [Who Are You? A Statistical Approach to Protecting LinkedIn Logins\(CSS UI Redressing Issue\)](#)
- [Evading All Web Application filters](#)
- [Multiple Facebook Messenger CSRF's](#)
- [Relative Path Overwrite](#)
- [SMTP Injection via Recipient Email Address](#)
- [Serverside Template Injection](#)
- [Hunting Asynchronous Vulnerabilities](#)

Edit 3: Nominations have now ended and voting has begun!

<https://www.surveymonkey.co.uk/r/RXJE3QW> ***CLOSED***

Edit 2: Submissions have been extended to February 1st! Keep sending in those submissions! Currently we have 32 entries!

Edit: We will be updating this post with nominations as they are received and vetted for relevance. Please email them to Top10Webhacks[at/]whitehatsec[dot]com.

Final 15:

- [Abusing CDN's with SSRF Flash and DNS](#)
- [Abusing XLST for Practical Attacks](#)
- [Breaking HTTPS With BGP Hijacking](#)
- [Evading All* WAF XSS Filters](#)
- [Exploiting XXE in File Parsing Functionality](#)
- [FileCry](#)
- [The New Age of XXE](#)
- [FREAK\(Factoring attack on RSA-Export Keys\)](#)
- [Hunting ASynchronous Vulnerabilities](#)
- [IllusoryTLS](#)
- [LogJam](#)
- [Magic Hashes](#)

- [Pawnstorm](#)
- [Relative Path Overwrite](#)
- [Server Side Template Injection](#)
- [Web Timing Attacks Made Practical](#)



1

Tags: [Vulnerabilities](#), [web application security](#)



Top 10 Website Hacking Techniques of 2014

Learn the top 10 website hacking techniques for the year.

Top 10 Web Hacking Techniques 2013

Every year the security community produces a stunning number of new Web hacking techniques that are published in various white papers, blog posts, magazine articles, mailing list emails, conference pr...

In The News

SANTA CLARA, Calif. – April 20, 2016
– WhiteHat Security, the only application security provider that combines the best of technology and human intelligence, today announced the Top 10 List of Web Hac...

Complying with PCI DSS 3.1 Guidelines

If your business deals with credit cards, mobile and online payments, learn more about complying with PCI DSS guidelines.

Unfilled Jobs in Cyber Security

Companies all over the globe are scrambling to fill jobs in Cyber Security positions and competing with each other for available talent to ensure a safe digital life.

DevOps Invites Security to "Join the Party"

DevSecOps takes a holistic approach, with everyone who touches an application, from development through testing and into production, sharing security DevOps goals.

Subscribe to Communications:



Follow us on:



[Products](#)

[Dynamic Application Security Testing \(DAST\)](#)

[Static Application Security Testing \(SAST\)](#)

[Customers](#)

[Case Studies](#)

[Support](#)

[Partners](#)

[Technology Partners](#)

[Resale Partners](#)

[Company](#)

[Leadership](#)

[Threat Research Center](#)

[In The News](#)

[Industry Recognition](#)

[Blog](#)

[Glossary](#)

[Learning Labs](#)

[Resources](#)

[Trending Now](#)

[Tweets by](#)

[@whitehatsec](#)

[Mobile Application
Security Testing](#)

[Computer-Based
Training](#)

[Solutions By Role](#)

[Solutions By Need](#)

[Solutions By
Industry](#)

[Careers](#)

[Events Calendar](#)

[Community](#)

[Contact](#)

WhiteHat Security © 2017

The front line of application security.

[Terms & Conditions](#)

| [Safe Harbor Privacy Policy](#)

